

Laporan Proyek UAS



Disusun oleh:

Alfandi Wijaya (232200156)

Keanrich Cordana (232301226)

Calvin Institute of Technology

IBDA 2112 - Keamanan dan Pengelolaan Data

Semester Genap 2024/2025

1. Pencarian Dataset dan Identifikasi PII

Dataset diambil berasal repository publik yang berisikan data pasien yang masuk dan keluar rumah sakit yang kami kumpulkan dalam folder *Dataset_Hospital_Full*. Data yang diambil merupakan penggabungan dari 2 tabel data menjadi yaitu tabel encounter pada file *encounter.csv* dan tabel patients pada file *patient.csv* yang kami merge menjadi *merged_ordered_data.csv*.



Personally Identifiable Information (PII) menurut tiga standar utama—GDPR, NIST, dan ISO/IEC 29100—merupakan informasi yang dapat digunakan untuk mengidentifikasi secara langsung maupun tidak langsung seorang individu. Menurut **GDPR Pasal 4(1)**, PII (disebut *personal data*) adalah segala informasi yang berkaitan dengan orang yang dapat diidentifikasi, baik melalui identifikasi langsung seperti nama, atau tidak langsung seperti lokasi dan identifikasi online. **NIST SP 800-122** mendefinisikan PII sebagai informasi apapun tentang individu yang dikelola oleh suatu entitas yang dapat digunakan untuk membedakan atau melacak identitas seseorang, seperti nama, nomor identifikasi, atau data lokasi. Sementara itu, **ISO/IEC 29100** menggambarkan PII sebagai setiap informasi yang dapat digunakan untuk mengidentifikasi atau yang mungkin dikaitkan dengan individu subjek data (PII principal), baik secara langsung maupun melalui pengaitan dengan data lain.

Berdasarkan dataset yang diambil terdapat beberapa kolom yang berisikan data PII. Sebagai contoh GDPR pasal 9 dan NIST SP 800-122 menuliskan bahwa data yang membahas mengenai **ras, lokasi tempat tinggal, tempat-tanggal lahir dan lokasi geografis** termasuk dalam PII. Selain itu pada dataset dapat ditemukan kolom yang memberikan **informasi dari penyakit pasien**. Menurut NIST SP 800-122 dan GDPR pasal 9 informasi riwayat penyakit dari pasien termasuk kedalam jenis data PII sensitif yang dapat membawa risiko tinggi terhadap diskriminasi dan stigma berlebihan terhadap pasien.

Sumber dataset : <https://mavenanalytics.io/data-playground?page=3&pageSize=5>

2. Desain Skenario Kebutuhan Privasi dan Teknik Perlindungan Data

Bagi banyak masyarakat di seluruh dunia, aspek kesehatan sering kali menjadi salah satu komponen pengeluaran terbesar dalam kehidupan mereka. Tak sedikit individu dan keluarga yang secara proaktif berupaya membangun tabungan atau simpanan jangka panjang sebagai bentuk antisipasi terhadap kemungkinan biaya kesehatan yang tinggi di masa depan, termasuk melalui kepemilikan asuransi kesehatan. Oleh karena itu, penting untuk dilakukan analisis yang komprehensif mengenai seberapa besar dampak perlindungan asuransi terhadap pengeluaran riil masyarakat, serta seberapa besar biaya yang masih harus ditanggung secara mandiri di luar pertanggungan asuransi. Dengan tersedianya data mengenai biaya dasar layanan kesehatan (base encounter cost), total klaim biaya (total claim cost), dan jumlah yang ditanggung oleh pihak asuransi (payer coverage), analisis perbandingan ketiga komponen ini dapat memberikan gambaran yang lebih akurat dan menyeluruh mengenai beban finansial masyarakat dalam mengakses layanan kesehatan.

Analisis dari dampak dari perlindungan asuransi terhadap pengeluaran riil masyarakat tentu akan memunculkan beberapa risiko pelanggaran privasi dalam prakteknya. Sebagai contoh pengelola data bisa saja mengambil data PII (tempat tinggal dan koordinat tempat tinggal) dari pasien kemudian menyebarkannya ke pasar penjualan data (data bocor). Selain itu, data secara utuh tentu akan mengundang pihak ketiga untuk dapat melakukan klaim dari identitas yang bukan semestinya (mengambil identitas pasien) dan melakukan pencurian barang berharga dari asuransi pasien. Terlebih lagi terdapat informasi mengenai riwayat dari penyakit pasien yang memiliki risiko terjadinya diskriminasi dan stigma dari individu tersebut.

Untuk mengurangi risiko, pelaku analisis data dapat melakukan beberapa hal seperti melakukan minimisasi dari data PII yang sensitif seperti tempat lahir, negara bagian, kota asal, etnos, ras, dan koordinat tempat tinggal untuk menghindari data PII dapat bocor pada tangan yang salah. Selain itu, perlu dilakukan minimisasi data pada data-data tidak relevan yang tidak bisa digunakan untuk menganalisis data seperti organisasi, payer, patient, suffix, reasoncode, dan code. Pada data-data yang PII namun tidak sensitif seperti nama, tanggal lahir, pewart, alamat, prefix, gender, tanggal keluar masuk rumah sakit, penyakit, dan lain-lain perlu dilakukan Pseudonimisasi. Pseudonimisasi dapat dilakukan dengan menggunakan masking dan enkripsi untuk menyembunyikan data. Kemudian untuk menyembunyikan hasil analisis dilakukan anonimisasi dengan menambahkan *noise* pada hasil analisis.

3. Perancangan Kebijakan Privasi (Privacy Policy)

Sebuah perusahaan yang melakukan pengambilan data dari pengguna bertanggung jawab untuk melindungi dan menghormati setiap individu yang datanya dikumpulkan dan digunakan berdasarkan prinsip-prinsip yang sudah ada pada General Data Protection Regulation (GDPR), National Institute of Standards and Technology (NIST), dan ISO.

Adapun tiga pihak yang terlibat dalam siklus data dan memiliki hak serta kewajiban yang ada yaitu Subjek Data (Pengguna/Pemilik Data), Pengumpul Data (Institusi), dan Konsumen data (Pihak ketiga/Mitra/ Peneliti).

- Hak Hak Subjek Data:

Hak	Penjelasan
Hak untuk diberi informasi	- <i>(GDPR Art. 13–14)</i>Subjek data berhak mengetahui siapa pengumpul data, tujuan pengumpulan, dasar hukum, serta durasi penyimpanan. - NIST ID.IM-3 (Data subjects are informed about data processing) - ISO 27701 Clause 7.3.3 – Providing Information to PII Principals
Hak untuk mengakses data	- <i>(GDPR Art. 15)</i>Subjek data dapat meminta salinan data pribadi yang disimpan serta informasi tambahan seperti kategori data, penerima data, dan asalnya. - NIST CM.AW-P1 (Provide mechanisms for individuals to access their data) - ISO 27701 Clause 7.3.4 – Providing Mechanism to Modify or Withdraw Consent
Hak untuk memperbaiki data	- <i>(GDPR Art. 16)</i>Memungkinkan pengguna memperbaiki data yang tidak akurat atau tidak lengkap. - NIST CM.AW-P2 (Individuals can request correction of data) - ISO 27701 Clause 7.3.6 – Access, Correction And/or Erasure
Hak untuk menghapus data ("Right to be Forgotten")	- <i>(GDPR Art. 17)</i>Berhak meminta penghapusan data jika data tidak lagi diperlukan, jika menarik persetujuan, atau jika data diproses secara ilegal.

	- NIST CM.AW-P3 (Mechanism to request data deletion) - ISO 27701 Clause 7.3.6 – Access, Correction And/or Erasure
Hak untuk membatasi pemrosesan	- <i>(GDPR Art. 18)</i>Subjek dapat meminta agar data tidak diproses lebih lanjut, hanya disimpan. - NIST CM.AW-P4 (Controls on use and sharing of personal data) - ISO 27701 Clause 7.3.7 – PII Controllers’ Obligations to Inform Third Parties
Hak atas portabilitas data	- <i>(GDPR Art. 20)</i>Subjek berhak menerima data dalam format terstruktur (misalnya JSON/CSV) dan mentransfernya ke pengendali lain. - NIST CM.AW-P5 (Data portability mechanisms) - ISO 27701 Clause 7.3.8 – Providing Copy of PII Processed
Hak untuk menolak pemrosesan	- <i>(GDPR Art. 21)</i>Dapat menolak penggunaan data untuk kepentingan tertentu, seperti pemasaran langsung atau profil risiko. - CT.DP-P1 (Limitations on automated decision making) - ISO 27701 Clause 7.3.5 – Providing Mechanism to Modify or Withdraw Consent
Hak terhadap keputusan otomatis	- <i>(GDPR Art. 22)</i>Subjek data tidak boleh menjadi subjek keputusan berbasis otomatisasi (misalnya, profiling risiko) tanpa persetujuan eksplisit. - ISO 27701 Clause 7.3.10 – Automated Decision Making

Sumber GDPR: <https://gdpr-info.eu/>

Sumber NIST: <https://www.nist.gov/privacy-framework>

Sumber ISO/ESS: <https://www.isms.online/iso-27701/clause-7-3-obligations-to-pii-principals/>

- Tanggung Jawab Pengumpul Data:

Tanggung Jawab	Penjelasan
Lawfulness, Fairness, Transparency	- (GDPR Art. 5(1)(a))Data hanya boleh dikumpulkan dengan dasar hukum yang sah dan diproses secara transparan. - NIST GV.PO-P1: Organizational privacy values and policies are established and communicated.
Purpose Limitation	- (GDPR Art. 5(1)(b))Data dikumpulkan untuk tujuan spesifik, eksplisit, dan sah, dan tidak diproses lebih lanjut di luar tujuan tersebut.
Data Minimization	- (GDPR Art. 5(1)(c))Hanya data yang benar-benar diperlukan yang boleh dikumpulkan. - NIST 800-53 (Collect only necessary data)
Accuracy	(GDPR Art. 5(1)(d))Data harus akurat dan selalu diperbarui. Pengumpul wajib memperbaiki kesalahan tanpa penundaan.
Storage Limitation	(GDPR Art. 5(1)(e))Data tidak disimpan lebih lama dari yang diperlukan. Jadwal retensi data perlu ditetapkan.
Integrity and Confidentiality	(GDPR Art. 5(1)(f), Art. 32)Pengumpul wajib menjaga keamanan data melalui enkripsi, kontrol akses, dan audit log.
Accountability	(GDPR Art. 5(2), Art. 24)Institusi bertanggung jawab dan harus bisa menunjukkan kepatuhan terhadap GDPR.
Data Protection Impact Assessment (DPIA)	(GDPR Art. 35)Untuk pemrosesan risiko tinggi, DPIA wajib dibuat sebelum pengumpulan data.
Laporan Pelanggaran (Breach Notification)	- (GDPR Art. 33–34)Pelanggaran data harus dilaporkan ke otoritas dalam waktu 72 jam dan ke subjek jika berdampak serius. - NIST SP 800-61 Rev. 2 (Incident Response)

Sumber GDPR: <https://gdpr-info.eu/>

Sumber NIST:

<https://www.nist.gov/system/files/documents/2021/05/05/NIST-Privacy-Framework-V1.0-Core-PDF.pdf>

- Tanggung Jawab Konsumen Data:

Tanggung Jawab	Penjelasan
Pemrosesan berdasarkan Perjanjian Tertulis	<i>(GDPR Art. 28)</i> Hanya boleh mengakses data melalui kontrak tertulis dari pengumpul data, dengan klausul tentang keamanan dan tujuan penggunaan.
Kepatuhan terhadap Tujuan Awal	<i>(GDPR Art. 29)</i> Data hanya boleh digunakan untuk tujuan yang disebutkan oleh pengumpul data.
Tidak boleh menyimpan data lebih lama dari ketentuan	<i>(GDPR Art. 5(1)(e))</i> Durasi penyimpanan data harus sesuai dengan yang ditetapkan pengumpul data.
Transfer data lintas negara harus terlindungi	<i>(GDPR Art. 44–50)</i> Jika data ditransfer ke luar Uni Eropa, harus ada perlindungan hukum tambahan (misalnya, SCC, BCR).
Melakukan enkripsi atau pseudonimisasi	<i>(GDPR Art. 32)</i> Wajib menerapkan kontrol teknis seperti enkripsi saat data disimpan atau ditransmisikan.
Tidak mencoba mengidentifikasi ulang data anonim	<i>(GDPR Prinsip minimisasi dan pseudonimisasi)</i> Jika menerima data anonim, tidak boleh dicoba untuk mengungkapkan identitas subjek.

Sumber GDPR: <https://gdpr-info.eu/>

4. Desain Mekanisme Pertukaran Data yang Aman

4.1. Enkripsi Untuk Pengiriman Data

Pada bagian ini, kami menggunakan kombinasi enkripsi simetris dan asimetris dengan menggunakan library cryptography untuk melakukan enkripsi data. Kami menggunakan enkripsi AES untuk mengenkripsi data yang kita miliki lalu AES key akan kami enkripsi menggunakan public key dari receiver (Asimetris). Hal ini dilakukan untuk memperketat hasil enkripsi. lalu keseluruhan hasil enkripsi akan didekode menggunakan library base64 pada file encrypted_packet.bin yang nantinya file tersebut akan didekripsi menjadi data yang sesungguhnya.

Proses Enkripsi:

1. Pertama tama kita membuka kunci receiver public key yang akan kita gunakan untuk mengenkripsi AES key.
2. Membuat random AES-256 key yang akan digunakan untuk mengenkripsi data.
3. Mengenkripsi AES key menggunakan Receiver Public Key (Enkripsi Asimetris)
4. Membaca File CSV yang akan dikirimkan, lalu di enkripsi menggunakan AES key (Enkripsi Simetris)
5. Membaca private key milik pengirim, lalu Menggunakan RSA digital signature dengan padding PSS dan SHA-256 untuk membuat tanda tangan atas data CSV yang sudah dienkripsi. Hal ini berguna untuk verifikasi keaslian data oleh penerima.
6. Semua komponen yaitu encrypted_csv, encrypted_aes_key, iv, dan signature diencode dengan Base64 agar bisa disimpan sebagai teks yaitu encrypted_packet.bin
7. File hasil enkripsi siap dikirim.

4.2. Dekripsi dan Verifikasi

Pada bagian ini, penerima melakukan verifikasi file yang telah dienkripsi untuk memastikan file tersebut tidak diubah oleh pihak ketiga selama pengiriman lalu apabila sudah terverifikasi penerima mendekripsi file yang telah dienkripsi oleh pengirim.

Proses Dekripsi dan Verifikasi:

1. Membaca Private key dari penerima untuk mengenkripsi AES key dan membaca public key dari sender untuk tujuan verifikasi.
2. Membaca file yang telah dienkripsi, lalu mendekode isi file dari Base64 menjadi byte kembali.
3. AES key didekripsi menggunakan kunci privat RSA milik penerima.
4. Verifikasi bahwa file hasil enkripsi benar-benar ditandatangani oleh pengirim menggunakan RSA signature. Jika verifikasi gagal, program keluar dengan pesan error.
5. Jika verifikasi berhasil, Data CSV didekripsi menggunakan AES dengan IV dan AES key hasil dekripsi RSA
6. Menyimpan hasil dekripsi ke dalam file baru yaitu decrypted_record.csv

Komitmen Integritas

“Di hadapan TUHAN yang hidup, saya menegaskan bahwa saya tidak memberikan maupun menerima bantuan apapun—baik lisan, tulisan, maupun elektronik—di dalam ujian ini selain daripada apa yang telah diizinkan oleh pengajar, dan tidak akan menyebarkan baik soal maupun jawaban ujian kepada pihak lain.”



Alfandi Wijaya



Keanrich Cordana